

CYBER SECURITY INCIDENT RESPONSE CONCEPT

VERSION: 1.3
DATE: 25/06/2019
AUTHOR: SYLVAIN MARTINEZ
REFERENCE: ES-CSIR
CLASSIFICATION: PUBLIC



CONTENTS

CONTEXT

- Presentation goal;
- Who am I;
- Who we are;
- Our customers;
- IR framework benefits;
- Data breach statistics;
- Incident cost;
- Incident readiness;
- Incident response concept;

STRUCTURE

- Teams and mandates;
- Registers and purposes;
- Registers and reporting synergy;
- IR policy & plan overview;
- Incident playbook overview;

HANDLING

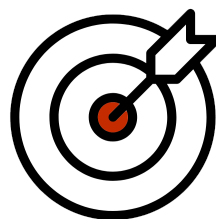
- NIST IR lifecycle;
- NIST IR steps;
- Preparation
- Detection & Analysis;
- Containment, Eradication & Recovery;
- Post-incident activity;
- Incident Response Check list

CASE STUDY

- ELYSIUMSECURITY Incident Response;
- Overview;
- Rules of Engagement;
- Preparation;
- Detection;
- Categorization;
- Containment;
- Investigation;
- Remediation;
- Reporting;
- Lessons Learnt;

CONCLUSION

- Short Term – How to start?;
- Long Term – IR Implementation;
- Extra Resources.



TO LEARN ABOUT CYBER INCIDENT RESPONSE (IR) MAIN CONCEPTS

1

**LEARN ABOUT IR CORE
ELEMENTS**

2

**LEARN HOW TO APPLY AN IR
FRAMEWORK**

3

LEARN HOW TO START

WHO AM I



LIVED AND WORKED IN **FRANCE, UK, USA** AND **MAURITIUS**



PASSIONATE ABOUT **IT** FROM VERY EARLY YEARS



VETTED, TRAINED AND **OVER 20 YEARS OF CYBER SECURITY EXPERIENCE** WORKING FROM LARGE INTERNATIONAL CORPORATIONS



CONTRIBUTING AND **LEADING** VARIOUS **OPEN SOURCE** CYBER SECURITY PROJECTS FOR THE LAST **20 YEARS**

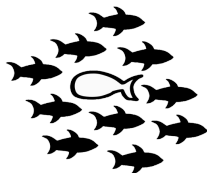


FOUNDER AND RUNNING THE **MAURITIUS SECURITY CLUB (MU.SCL)** WITH FREE SECURITY AWARENESS PRESENTATIONS EVERY MONTH

WHO WE ARE



FOUNDED IN **2015** BY **SYLVAIN MARTINEZ**
INCORPORATED AND OPERATING IN **MAURITIUS** (2017)
AND IN THE **UK/EUROPE** (2015)



PROVIDING **INDEPENDENT EXPERTISE** IN CYBER SECURITY



MULTITUDE OF RECOGNIZED **PROFESSIONAL CERTIFICATIONS**



20 YEARS OF INTERNATIONAL CYBER SECURITY **CORPORATE EXPERIENCE**



OUR **BOUTIQUE STYLE** APPROACH PROVIDES A **DISCREET, TAILORED**
AND **SPECIALIZED** CYBER SECURITY SERVICE THAT FITS YOUR WORKING
ENVIRONMENT

REFERENCES AVAILABLE ON DEMAND



- HEDGE FUNDS
- GOVERNMENT AGENCY SERVICE SUPPLIER

2016
2019



- 1x BANK
- 1x TELECOMMUNICATION GROUP

2018



- 4x LARGE COMMERCIAL GROUPS;
- 2x BANKS; 3x MANAGEMENT FUNDS;
- 6x HOTELS; 3x TEXTILE; 1x SHOPPING;
- 1x HEALTHCARE;

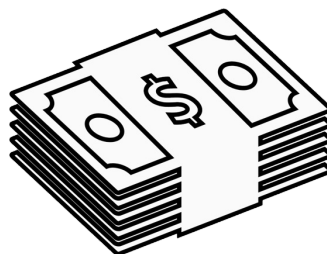
2017
2019

INCIDENT RESPONSE FRAMEWORK BENEFITS



IMPROVED SECURITY

- IMPROVED RESPONSE TIME
- IMPROVED INCIDENT CONTAINMENT
- IMPROVED INCIDENT VISIBILITY



REDUCED IMPACT COST

- REDUCED OPERATION DOWNTIME
- REDUCED INCIDENT IMPACT
- REDUCED/AVOID FINES



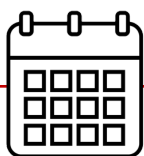
BUSINESS ENABLEMENT

- CONTRACT REQUIREMENT
- INDUSTRY REQUIREMENT
- LAW REQUIREMENT

DATA RECORDS LOST OR STOLEN SINCE 2013

14,717,618,286

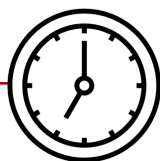
DATA RECORDS ARE LOST OR STOLEN AT THE FOLLOWING FREQUENCY



EVERY DAY

6,313,865

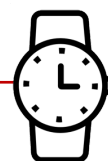
RECORDS



EVERY HOUR

263,078

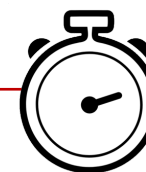
RECORDS



EVERY MINUTE

4,385

RECORDS



EVERY SECONDS

73

RECORDS

INCIDENT COST

ELYSIUMSECURITY INVESTIGATIONS

MAURITIUS

JANUARY 2018 – JUNE 2019

80% FINANCIAL FRAUD

20% RANSOMWARE

100% PHISHING

JAN 2018 \$0.5M

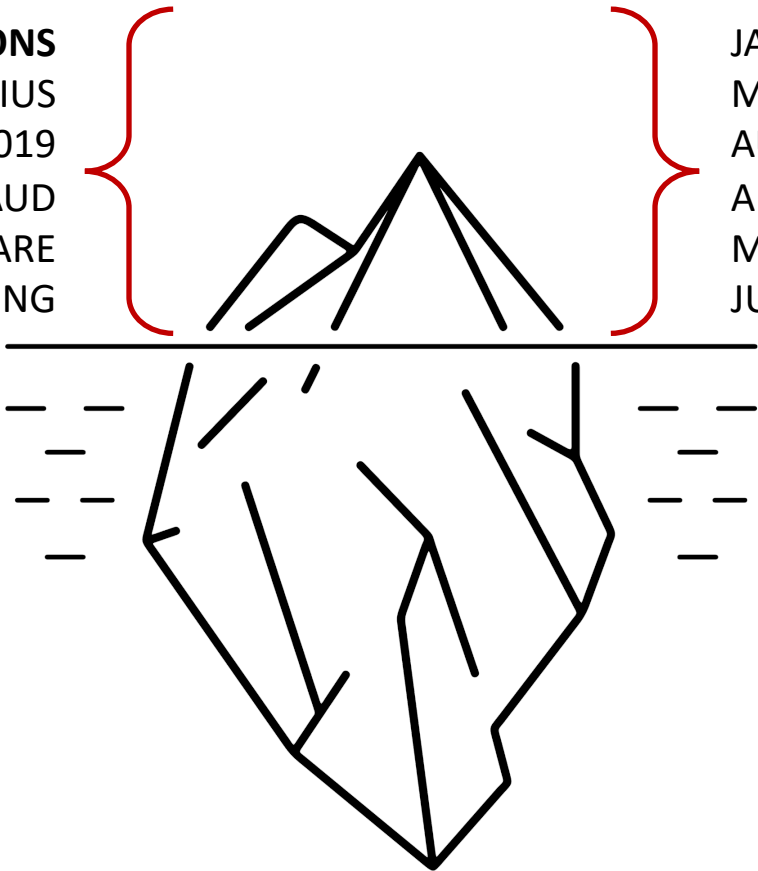
MAY 2018 \$1M

AUG 2018 \$2M

APR 2019 \$0.5M

MAY 2019 \$1M

JUNE 2019 \$0.5M



WORLDWIDE

\$3.86M

\$2.4M

197 DAYS

73%

24%

AVERAGE COST PER DATA BREACH

AVERAGE COST PER MALWARE INFECTION

AVERAGE DETECTION TIME

FROM OUTSIDERS CRIMINALS

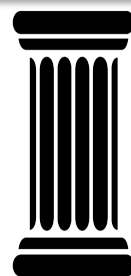
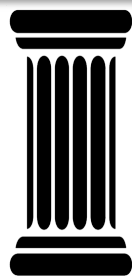
DATA BREACHES FROM HEALTHCARE ORGANISATIONS

INCIDENT READINESS



INCIDENT RESPONSE CONCEPT

TO MINIMISE OPERATIONAL, FINANCIAL & BUSINESS INCIDENT IMPACT



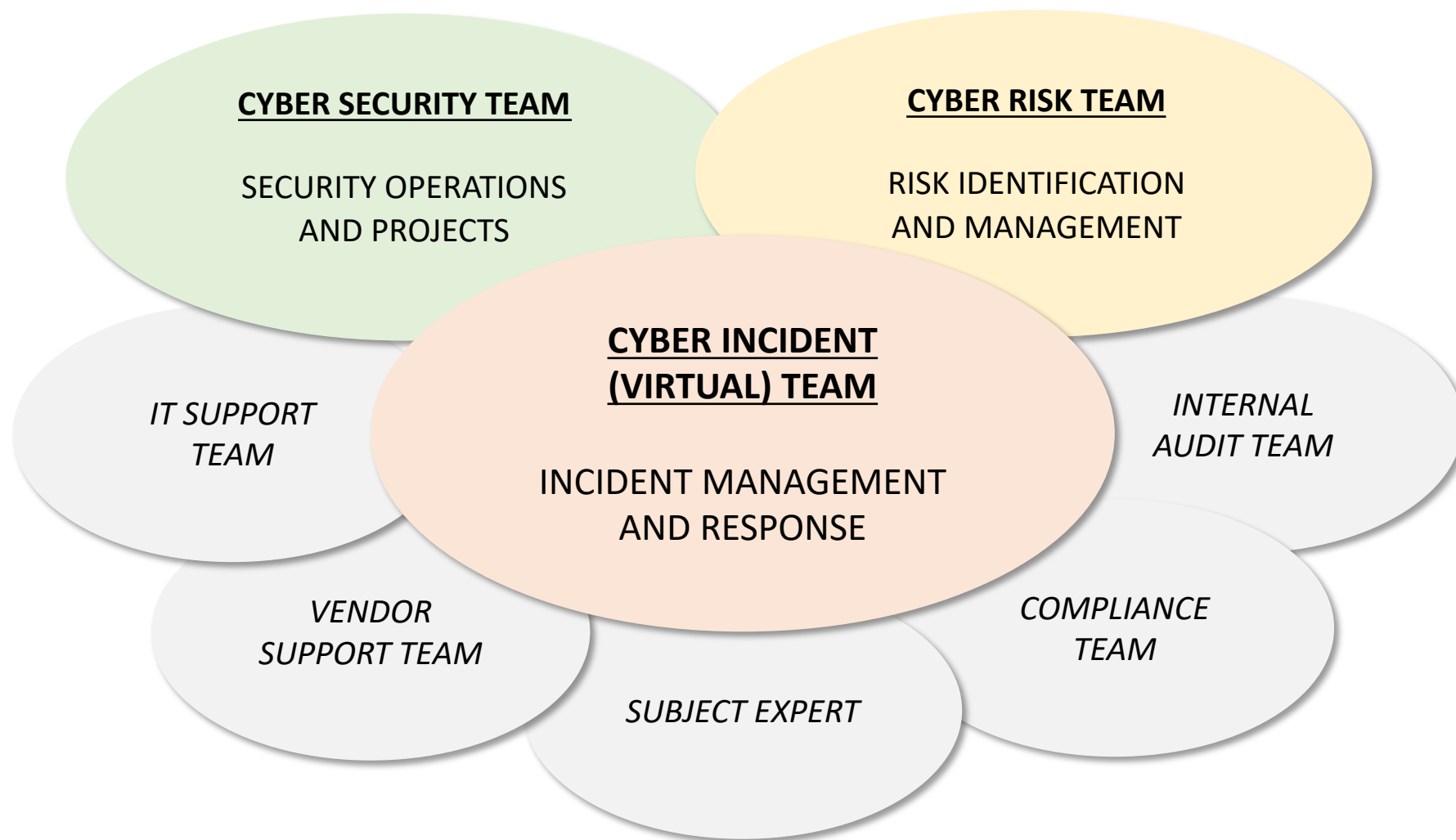
**COORDINATION
&
INFORMATION
SHARING**

INCIDENT RESPONSE HANDLING

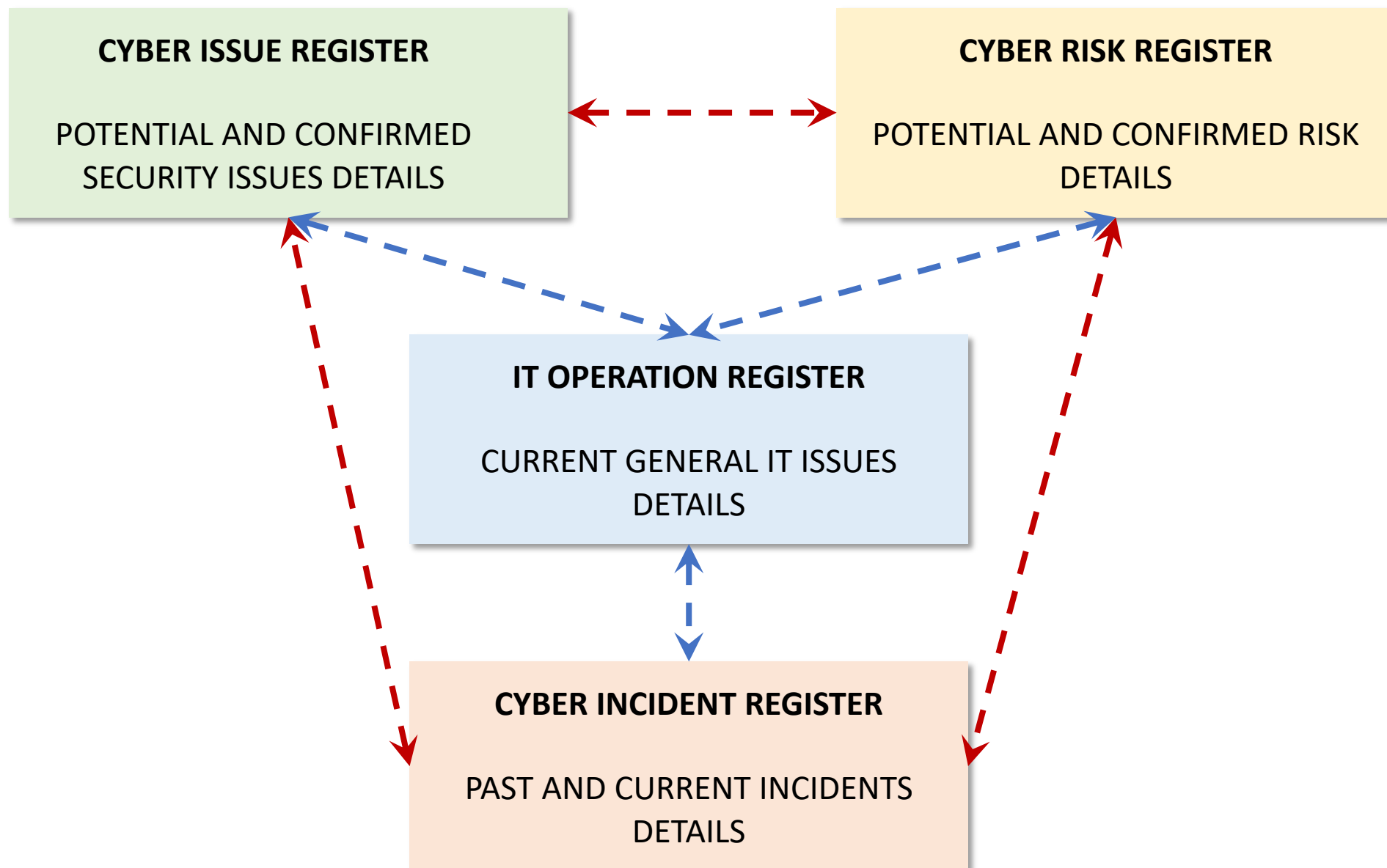
INCIDENT RESPONSE STRUCTURE

**NIST
SP 800-61**

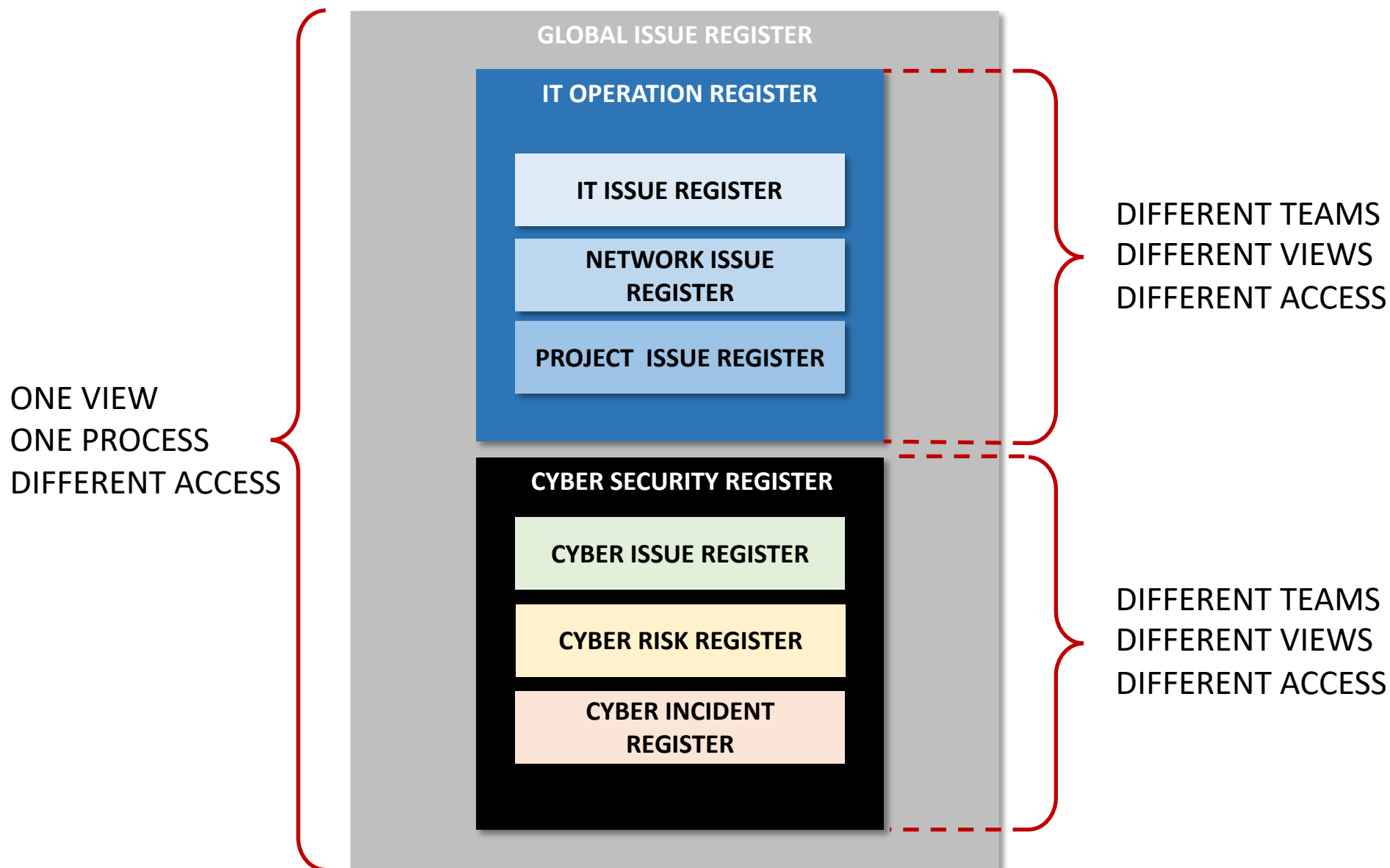
TEAMS AND MANDATES



REGISTERS AND PURPOSES



REGISTERS AND REPORTING SYNERGY



INCIDENT RESPONSE POLICY & PLAN - OVERVIEW

INCIDENT RESPONSE POLICY

INCIDENT SCOPE

INCIDENT DEFINITION &
PRIORITIZATION

INCIDENT REPORTING

INCIDENT RESPONSE PLAN

INCIDENT HANDLING

INCIDENT COORDINATION

CONTINUOUS
IMPROVEMENT

INCIDENT PLAYBOOK OVERVIEW

ANALYSE SIGNS OF INCIDENT

UNDERSTAND CAUSE
OF INCIDENT

CONTAIN INCIDENT

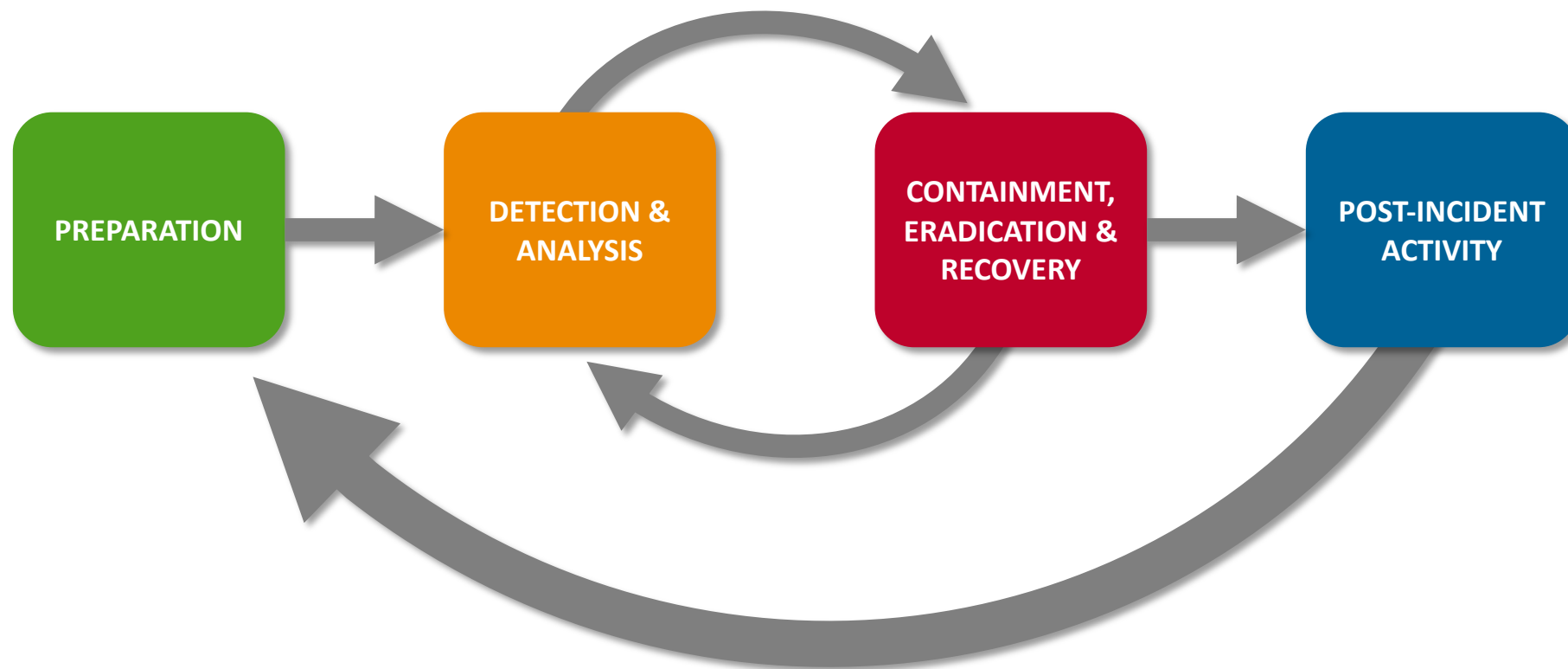
INCIDENT PLAYBOOK SCENARIOS

READY MADE SCENARIOS

PRACTICAL RESPONSE ACTIONS

AVAILABLE AND COMMUNICATED

NIST SP 800-61 REV 2



NIST INCIDENT RESPONSE - STEPS

PREPARATION

1. COMMUNICATION & FACILITIES

2. HARDWARE & SOFTWARE

3. RESOURCES

DETECTION & ANALYSIS

4. ATTACK VECTORS IDENTIFICATION

5. SIGN OF AN INCIDENT

6. SOURCE OF PRECURSORS

7. INCIDENT ANALYSIS

8. INCIDENT DOCUMENTATION

9. INCIDENT PRIORITIZATION

10. INCIDENT NOTIFICATION

CONTAINMENT, ERADICATION & RECOVERY

11. CONTAINMENT STRATEGY

12. EVIDENCE GATHERING & HANDLING

13. IDENTIFYING THE ATTACKING HOST

14. ERADICATION & RECOVERY

POST-INCIDENT ACTIVITY

15. LESSONS LEARNT

16. USING COLLECTED INCIDENT DATA

17. EVIDENCE RETENTION

PREPARATION - OVERVIEW

1. COMMUNICATION & FACILITIES

CONTACT DETAILS

PHYSICAL LOGISTICS

COORDINATION SYSTEM

2. HARDWARE & SOFTWARE

GENERAL IT SPARE
EQUIPMENT

FORENSICS SPECIFIC
EQUIPMENT

TRUSTED SOURCED
SOFTWARE

3. RESOURCES

ARCHITECTURE DIAGRAMS

DOCUMENTATION

INCIDENT PLAYBOOK

DETECTION & ANALYSIS - OVERVIEW

4. ATTACK VECTORS IDENTIFICATION

SOURCE OF ATTACK

TYPE OF ATTACK

METHOD OF
ATTACK

5. SIGN OF AN INCIDENT

NETWORK LOGS

SYSTEM LOGS

EXPLOIT
ANNOUNCEMENT

6. SOURCE OF PRECURSORS & INDICATORS

SECURITY ALERTS

SECURITY LOGS

PEOPLE FEEDBACK

7. INCIDENT ANALYSIS

BASELINES

LOG ANALYSIS

DATA RESULTS
FILTERING

DETECTION & ANALYSIS - OVERVIEW

8. INCIDENT DOCUMENTATION

STATUS

WORK DONE

NEXT STEPS

9. INCIDENT PRIORIZATION

FUNCTIONAL
IMPACT

INFORMATION
IMPACT

RECOVERABILITY

10. INCIDENT NOTIFICATION

UPPER
MANAGEMENT

STAFF

EXTERNAL BODIES

CONTAINMENT, ERADICATION & RECOVERY - OVERVIEW

11. CONTAINMENT STRATEGY

INCIDENT IMPACT

EVIDENCE REQUIREMENTS

SOLUTION SUSTAINABILITY

12. EVIDENCE GATHERING & HANDLING

INCIDENT INFORMATION

TIME AND DATE

LOCATION

13. IDENTIFYING THE ATTACKING HOST

SOURCE IP

ATTACKER RESEARCH

COMMUNICATION MONITORING

14. ERADICATION & RECOVERY

REMOVING IMMEDIATE THREAT

REMEDIATING VULNERABILITIES

GROUP WIDE CHANGES

POST INCIDENT ACTIVITY - OVERVIEW

15. LESSONS LEARNT

INCIDENT DETAILS

TECHNOLOGY AND
PROCESS GAPS

POSSIBLE
IMPROMENTS

16. USING COLLECTED INCIDENT DATA

INCIDENT
STATISTICS

INCIDENT SLA

INCIDENT
ASSESSMENT

17. EVIDENCE RETENTION

PROSECUTION

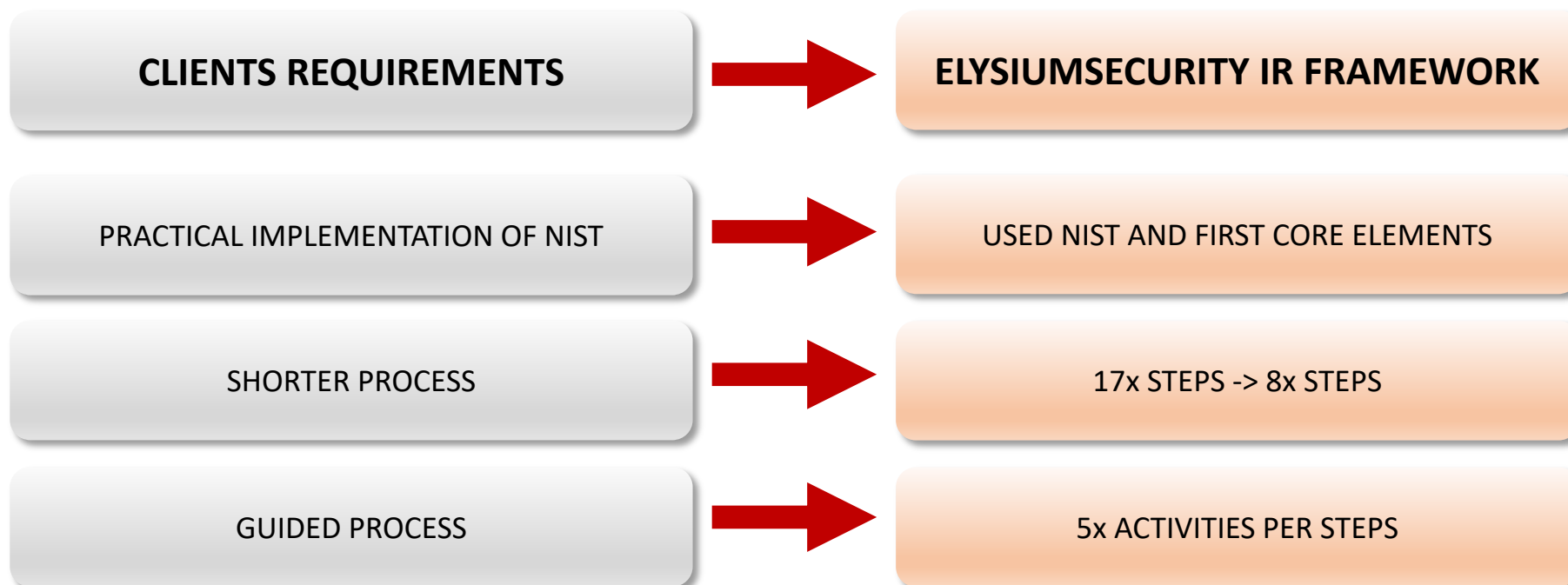
DATA RETENTION

COST

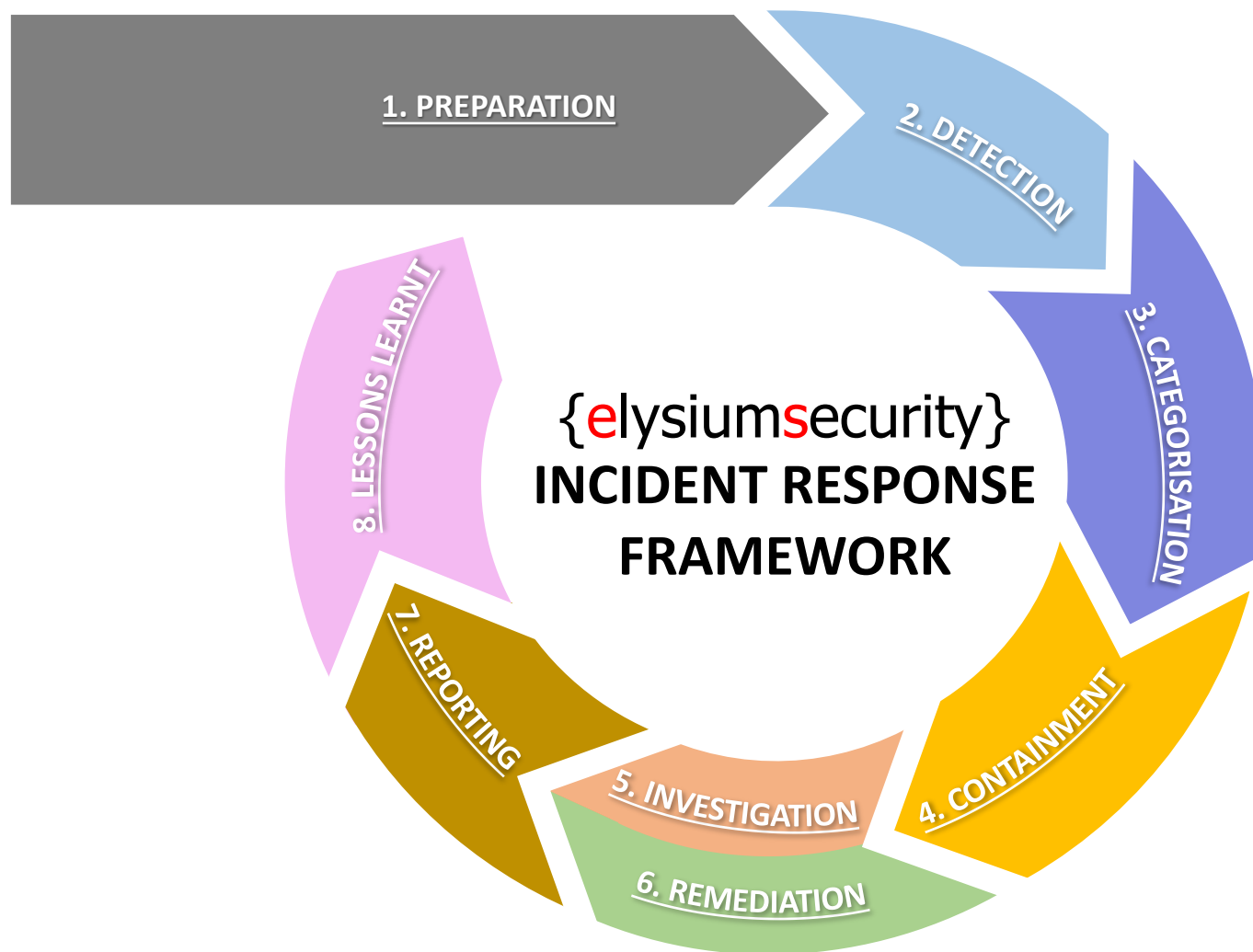
INCIDENT RESPONSE CHECKLIST

REF	ACTION	COMPLETED
Detection and Analysis		
1.	Determine whether an incident has occurred	
1.1	Analyze the precursors and indicators	
1.2	Look for correlating information	
1.3	Perform research (e.g., search engines, knowledge base)	
1.4	As soon as the handler believes an incident has occurred, begin documenting the investigation and gathering evidence	
2.	Prioritize handling the incident based on the relevant factors (functional impact, information impact, recoverability effort, etc.)	
3.	Report the incident to the appropriate internal personnel and external organizations	
Containment, Eradication, and Recovery		
4.	Acquire, preserve, secure, and document evidence	
5.	Contain the incident	
6.	Eradicate the incident	
6.1	Identify and mitigate all vulnerabilities that were exploited	
6.2	Remove malware, inappropriate materials, and other components	
6.3	If more affected hosts are discovered (e.g., new malware infections), repeat the Detection and Analysis steps (1.1, 1.2) to identify all other affected hosts, then contain (5) and eradicate (6) the incident for them	
7.	Recover from the incident	
7.1	Return affected systems to an operationally ready state	
7.2	Confirm that the affected systems are functioning normally	
7.3	If necessary, implement additional monitoring to look for future related activity	
Post-Incident Activity		
8.	Create a follow-up report	
9.	Hold a lessons learned meeting (mandatory for major incidents, optional otherwise)	

ELYSIUMSECURITY INCIDENT RESPONSE - OVERVIEW



ELYSIUMSECURITY INCIDENT RESPONSE - OVERVIEW



{**es**} **INCIDENT RESPONSE - RULES OF ENGAGEMENT**

1

DO NOT ENGAGE OR INTERACT WITH THE
HACKER/THREAT GROUP

2

DO NOT CONNECT TO THE THREAT'S RELATED
NETWORK(S) FROM YOUR ORGANISATION

3

PRESERVE EVIDENCE

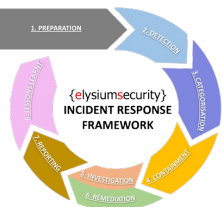
4

COORDINATE INTERNAL AND EXTERNAL
COMMUNICATION WITH MANAGEMENT

5

ALL INCIDENT DETAILS MUST BE TREATED AS
CONFIDENTIAL

DO NOT
MAKE
THINGS
WORSE!



1. PREPARATION

ACTIVITIES

EXAMPLE

1

INCIDENT RESPONSE PLAN

TEAM, PROCEDURES, DOCUMENTATION,
APPROVAL, MANAGEMENT COMMITMENT

2

INCIDENT RESPONSE PLAYBOOK

PHISHING, RANSOMWARE, KEYLOGGER, DDOS

3

LOGISTICS

MEETING ROOMS, LAPTOPS, REMOVABLE
STORAGE, PHONES, STATIONNARY, PRINTERS,
SLEEPING AND CATERING ARRANGEMENTS

4

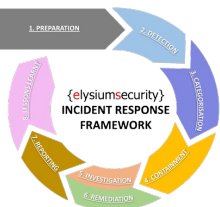
CONTACTS

TEAM, ALTERNATIVE CONTACT METHODS,
ESCALATION, ON CALL, SUPPORT, VENDOR,

5

SUPPORT

INCIDENT REGISTER, ARCHITECTURE DIAGRAM,
NETWORK DIAGRAM, DATA FLOWS, APPLICATION
AND SYSTEM DOCUMENTATION



2. DETECTION

ACTIVITIES

EXAMPLE

1

WHO/WHAT DETECTED/REPORTED THE THREAT?

IT STAFF, SECURITY TOOLS

2

WHAT IS THE DATE AND TIME OF THE THREAT
DETECTION/REPORT?

NORMALISE TIME AND DATE ACROSS
REPORTING – RECORD TIME IN GMT

3

HOW WAS THE THREAT DETECTED/REPORTED?

EMAIL, TEXT, WARNING POP UP, PHONE CALL

4

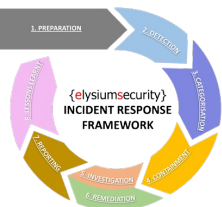
HAS A SIMILAR THREAT ALREADY BEEN
REPORTED?

PREVIOUS INCIDENT REGISTER LOGS

5

IS THE THREAT VALID?

CONFIRMED, FALSE POSITIVE



3. CATEGORISATION

ACTIVITIES

EXAMPLE

1

WHO/WHAT IS THE TARGET OF THE THREAT?

USER, SYSTEM, SPECIFIC DATA

2

IS THIS AN ON GOING/LIVE THREAT?

ON GOING, STOPPED, UNKNOWN

3

WHAT IS THE IMPACT OF THE THREAT?

FINANCIAL, OPERATIONAL, REPUTATIONAL,
LEGAL

4

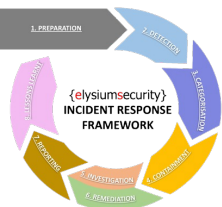
CATEGORISE THE PRIORITY OF THE INCIDENT

PRIORITY 1, 2 ,3 (P1 > P2 > P3)

5

CLASSIFY THE INCIDENT COMMUNICATION

RESTRICTED / UNRESTRICTED



4. CONTAINMENT

ACTIVITIES

EXAMPLE

1

COORDINATE INCIDENT MANAGEMENT

TEAM, COMMS, ACTIVITIES, DOCUMENTATION

2

LIGHT AND QUICK THREAT ANALYSIS

NETWORK, SYSTEM, USER

3

IDENTIFY MAIN ATTACK AND COMPROMISE
VECTORS

IP, PORTS, SIGNATURES, EMAIL

4

ISOLATE THE TARGETED ASSET

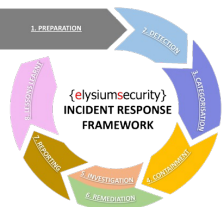
REMOVE FROM NETWORK, DISABLE ACCOUNT

5

IMPLEMENT EMERGENCY CHANGES AS
REQUIRED

NETWORK, SYSTEM, USER

{es} INCIDENT RESPONSE - INVESTIGATION



5. INVESTIGATION

ACTIVITIES

EXAMPLE

1

THREAT NETWORK ANALYSIS

FIREWALL, CLOUD APP LOGS, ASSET LOGS,
INTERCEPTED TRAFFIC, TRAFFIC AND DATA
FLOWS, SIEM

2

THREAT MALWARE ANALYSIS

A/V VENDORS, FOOTPRINT, BEHAVIOR, REVERSE
ENGINEERING

3

THREAT SYSTEM ANALYSIS

EVENT LOGS, APP/PLUGINS INSTALLED,
AD/EMAIL ACTIVITIES, AUTHENTICATED
VULNERABILITY ASSESSMENT, SIEM

4

THREAT USER ANALYSIS

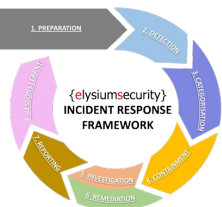
INTERVIEW TARGETED USER, CONTEXT,
TRIGGERS, RECENT UNUSUAL ACTIVITIES/ALERTS

5

THREAT RESEARCH ANALYSIS

ONLINE SEARCH FOR SIMILAR THREATS,
PROFESSIONAL FORUMS, VENDOR
ENGAGEMENT

ELYSIUMSECURITY INCIDENT RESPONSE - REMEDIATION



6. REMEDIATION

ACTIVITIES

EXAMPLE

1

THREAT NETWORK REMEDIATION

BLOCK IP, PORTS, DOMAINS, EMAILS.
UPDATE F/W, IDS, APT AND SIEM RULES

2

THREAT MALWARE REMEDIATION

UPDATE SYSTEM AND NETWORK A/V
SIGNATURES. ENGAGE WITH VENDORS

3

THREAT SYSTEM REMEDIATION

REMOVE/BAN INFECTED APPS/PLUGINS, CLEAR
INBOX RULES, REMEDIATE ISSUES FOUND WITH
THE VULNERABILITY ASSESSMENT

4

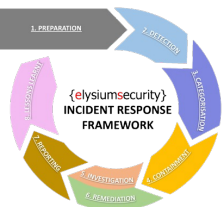
THREAT USER REMEDIATION

INDIVIDUAL AND GROUP USER AWARENESS
SESSION RELEVANT TO THE THREAT

5

DECLARE THE INCIDENT REMEDIATED

FULL, PARTIAL, ACCEPTED



7. REPORTING

ACTIVITIES

EXAMPLE

1

ON GOING REPORTING

DOCUMENTATION AND EVIDENCE SHOULD BE GENERATED AS MUCH AS POSSIBLE DURING THE PREVIOUS PHASES

2

EVIDENCE GATHERING

THREAT ACTORS, ATTACK VECTORS, ATTACK SURFACE

3

INCIDENT DOCUMENTATION

THREAT AND INCIDENT DETAILS, TRIGGERS, OWNER, FINDINGS, TIMELINE

4

INCIDENT REGISTER

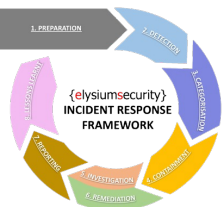
CREATE/UPDATE AN OVERALL INCIDENT REGISTER TO TRACK PROGRESS AND GENERATES STATISTICS

5

INCIDENT REPORT COMMUNICATION

INTERNAL, EXTERNAL, STAFF, MANAGEMENT, BOARD, VENDORS, CLIENTS, GOVERNMENT, REGULATORS, LAW ENFORCEMENT

{es} INCIDENT RESPONSE – LESSONS LEARNT



8. LESSONS LEARNT

ACTIVITIES

EXAMPLE

1

ROOT CAUSE ANALYSIS

IDENTIFY AND DOCUMENT INCIDENT TRIGGERS AND SECURITY GAPS THAT ENABLED THE INCIDENT TO OCCUR

2

CONTROLS AND PROCESSES READINESS

EVALUATE THE EFFICIENCY OF CURRENT SECURITY CONTROLS AND PROCESSES IN LIGHT OF THE INCIDENT

3

INCIDENT TRENDS ANALYSIS

ARE YOU LEARNING FROM PAST INCIDENTS? IS YOUR RISK PROFILE CHANGING?

4

MITIGATION PLAN

MITIGATE IMPACT OF SIMILAR FUTURE INCIDENTS

5

IMPROVEMENTS PLAN

STOP OCCURRENCE OF SIMILAR FUTURE INCIDENTS

SHORT TERM – HOW TO START?

1

REVIEW EXISTING INCIDENT PROCESS

6

INFORM STAFF OF RULES AND
INCIDENT CONTACT

2

ESTABLISH INCIDENT TEAM

7

CREATE INCIDENT REGISTER

3

CONDUCT REGULAR INCIDENT TEAM
MEETING

8

DOCUMENT RECENT AND FUTURE
INCIDENTS

4

SET GROUND RULES

9

FOLLOW NIST INCIDENT HANDLING
METHODOLOGY

5

DEFINE WHAT IS AN INCIDENT

10

CREATE HIGH LEVEL PLAYBOOK TO
COMPLEMENT CHECKLIST

LONG TERM – INCIDENT RESPONSE IMPLEMENTATION

1

**SELECT INCIDENT RESPONSE FRAMEWORK
(NIST SP 800-61 REV 2 RECOMMENDED)**

2

**IMPLEMENT FULL INCIDENT RESPONSE
FRAMEWORK**

3

**DEDICATED INCIDENT RESPONSE TEAM AND
TRAINING**

4

INCIDENT RESPONSE SIMULATION

5

CONTINUOUS IMPROVEMENT

FORUM OF INCIDENT RESPONSE AND SECURITY TEAMS (FIRST) FRAMEWORK

([HTTPS://WWW.FIRST.ORG/EDUCATION/FIRST_SIRT_SERVICES_FRAMEWORK_VERSION1.0.PDF](https://www.first.org/education/first_sirt_services_framework_version1.0.pdf))

NATIONAL INSTITUTE OF STANDARDS & TECHNOLOGY (NIST) SPECIAL PROCEDURE (SP) 800-61

([HTTPS://NVL PUBS.NIST.GOV/NISTPUBS/SPECIALPUBLICATIONS/NIST.SP.800-61R2.PDF](https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-61r2.pdf))

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION (ISO) ISO/IEC 27035-1:2016

([HTTPS://WWW.ISO.ORG/STANDARD/60803.HTML](https://www.iso.org/standard/60803.html))

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION (ISO) ISO/IEC 27035-2:2016

([HTTPS://WWW.ISO.ORG/STANDARD/62071.HTML?BROWSE=TC](https://www.iso.org/standard/62071.html?BROWSE=TC))

CONTACT US!

(CONSULTING@ELYSIUMSECURITY.COM)

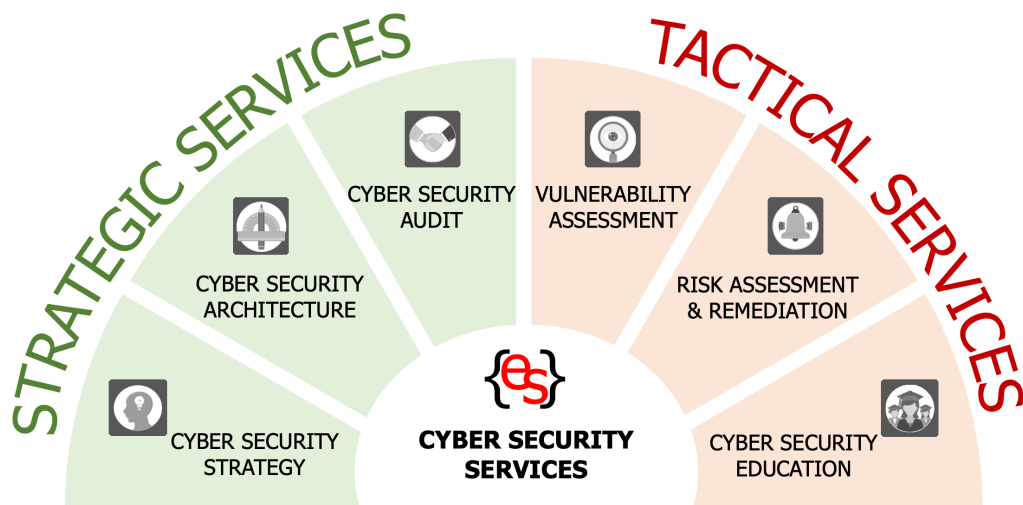
ABOUT ELYSIUMSECURITY LTD.

ELYSIUMSECURITY PROVIDES A PORTFOLIO OF **STRATEGIC** AND **TACTICAL SERVICES** TO HELP COMPANIES **PROTECT** AND **RESPOND** AGAINST **CYBER SECURITY THREATS**. WE DIFFERENTIATE OURSELVES BY OFFERING **DISCREET, TAILORED** AND **SPECIALIZED** ENGAGEMENTS.

ELYSIUMSECURITY OPERATES IN **MAURITIUS** AND IN **EUROPE**, A **BOUTIQUE STYLE** APPROACH MEANS WE CAN **EASILY ADAPT** TO YOUR BUSINESS OPERATIONAL MODEL AND REQUIREMENTS TO PROVIDE A **PERSONALIZED SERVICE** THAT FITS YOUR WORKING ENVIRONMENT.

ELYSIUMSECURITY PROVIDES **HIGH LEVEL EXPERTISE** GATHERED THROUGH YEARS OF **BEST PRACTICES EXPERIENCE** IN LARGE INTERNATIONAL COMPANIES ALLOWING US TO PROVIDE ADVICE BEST SUITED TO YOUR **BUSINESS OPERATIONAL MODEL** AND **PRIORITIES**.

ELYSIUMSECURITY PROVIDES **PRACTICAL EXPERTISE** TO **IDENTIFY VULNERABILITIES**, ASSESS THEIR **RISKS** AND **IMPACT**, **REMEDIATE** THOSE RISKS, **PREPARE** AND **RESPOND** TO INCIDENTS AS WELL AS RAISE **SECURITY AWARENESS** THROUGH AN ORGANIZATION.



© 2015-2019 ELYSIUMSECURITY LTD
ALL RIGHTS RESERVED

[HTTPS://WWW.ELYSIUMSECURITY.COM](https://www.elysiumsecurity.com)
CONSULTING@ELYSIUMSECURITY.COM